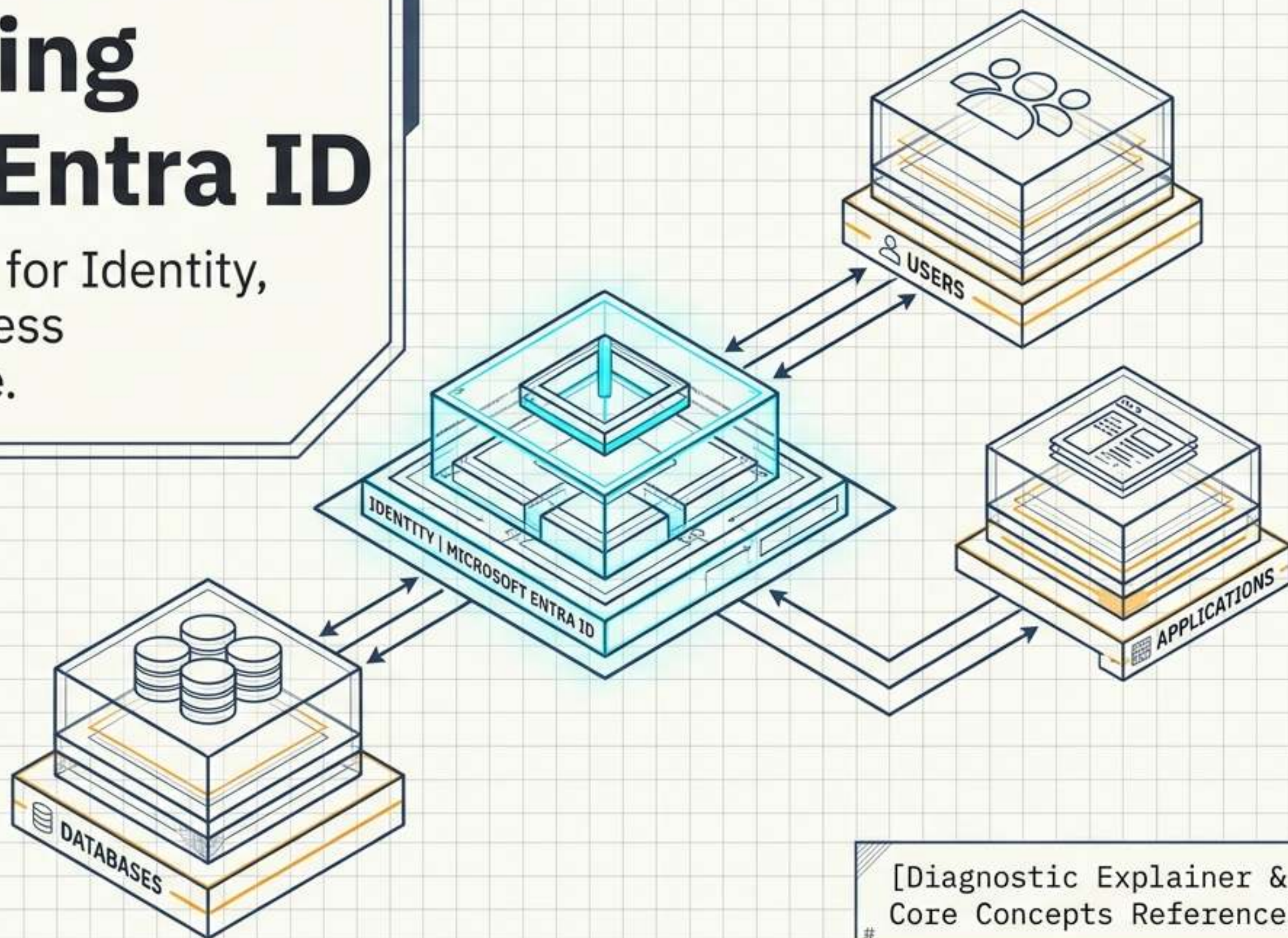


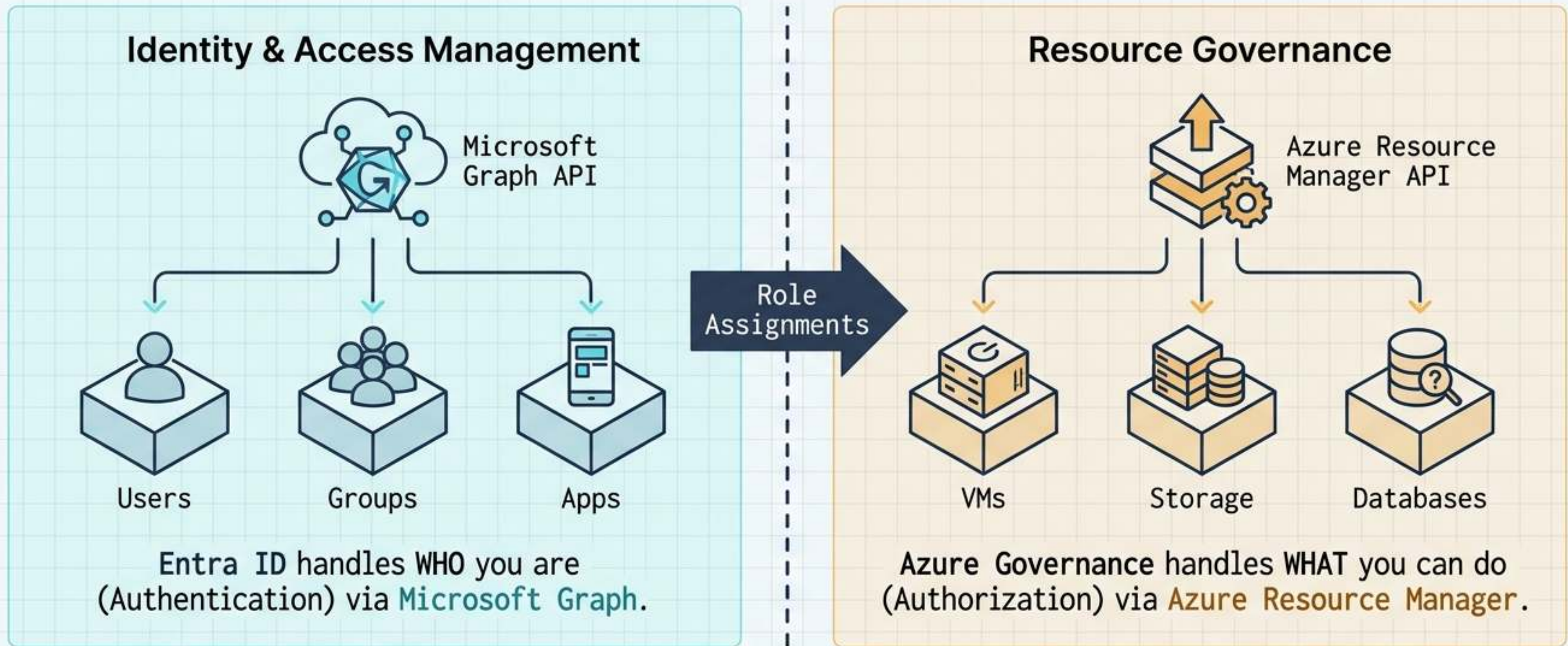
Demystifying Microsoft Entra ID

A Technical Blueprint for Identity, Governance, and Access Management in Azure.



[Diagnostic Explainer & Core Concepts Reference]

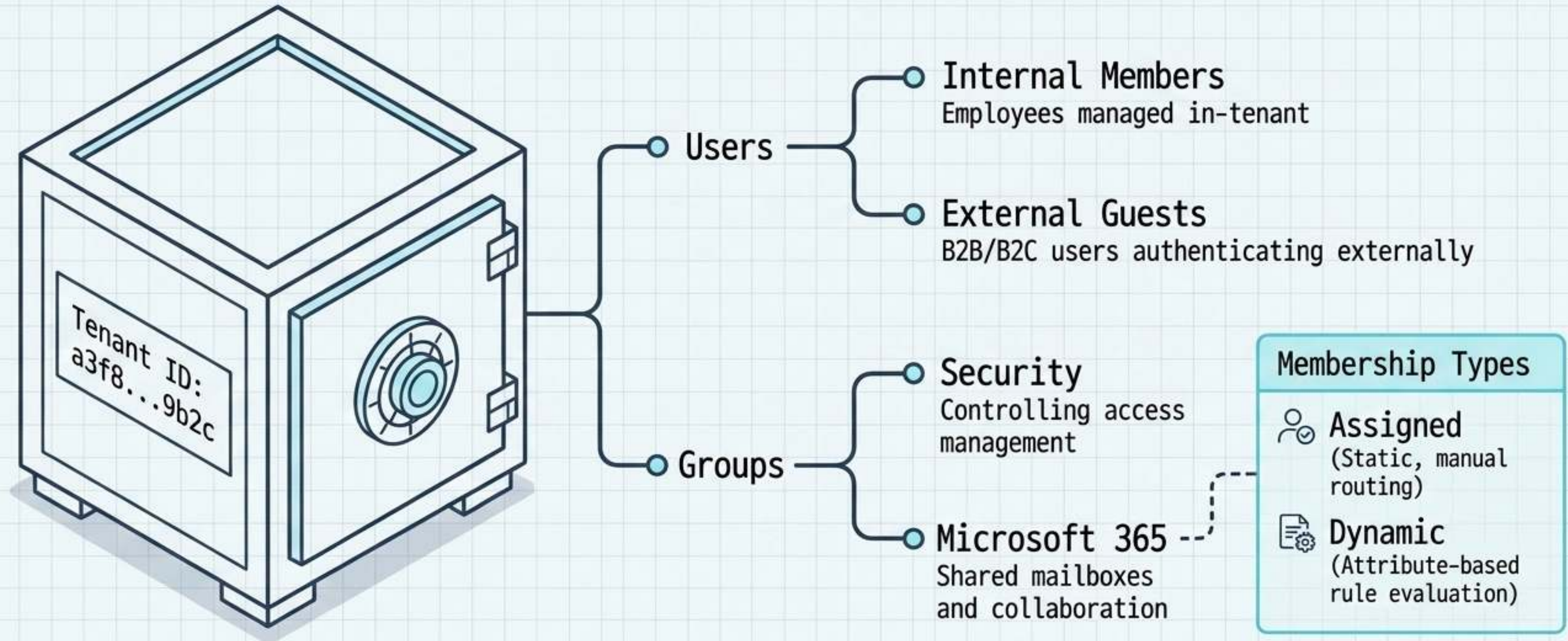
Two Distinct Control Planes Governed by One System



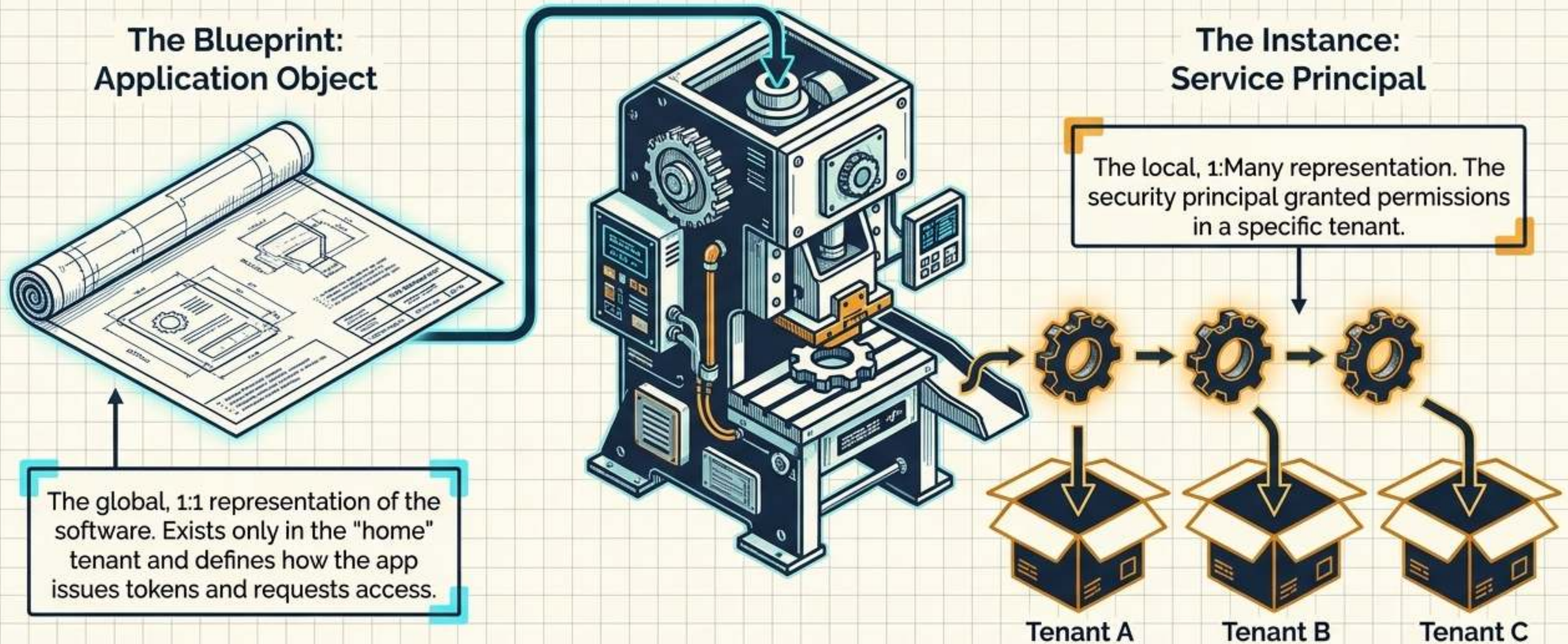
Insight: Mistaking these two planes is the leading cause of over-privileged environments and security gaps.

The Tenant Container and Directory Objects

A **Microsoft Entra Tenant** is a dedicated, trusted instance. It represents the absolute boundary of trust.



Non-Human Identities: The Blueprint vs. The Instance



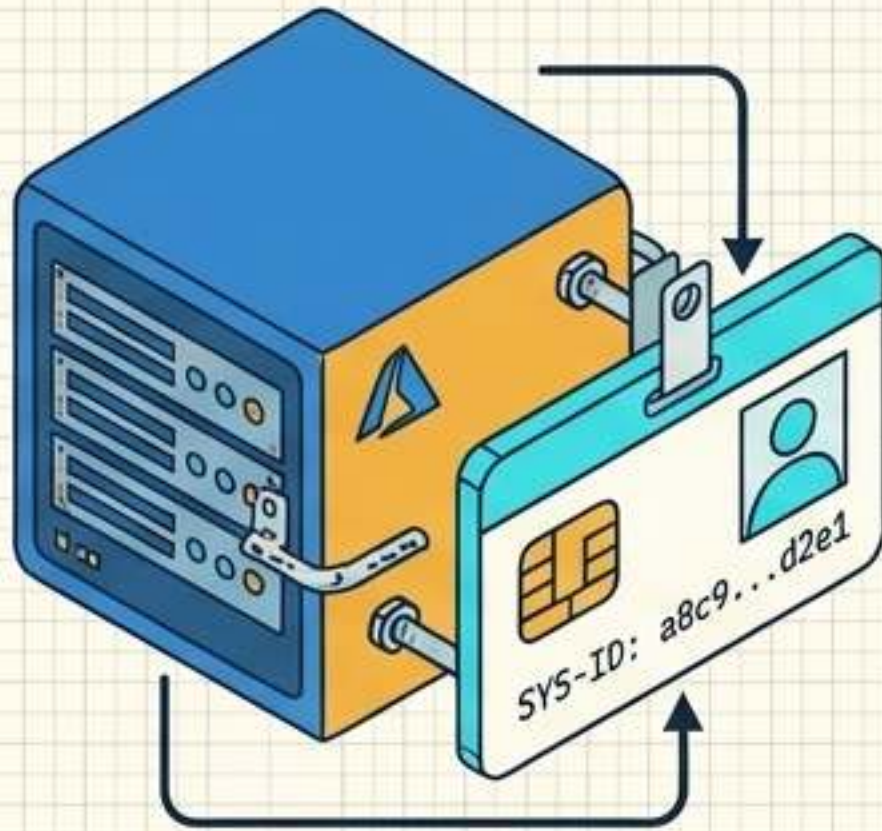
Key Rule: A multitenant app has **exactly one App Object**, but **many Service Principals** distributed across every customer's tenant.

Managed Identities Automate Credential Lifecycles

Managing service principal secrets is a massive security vulnerability.

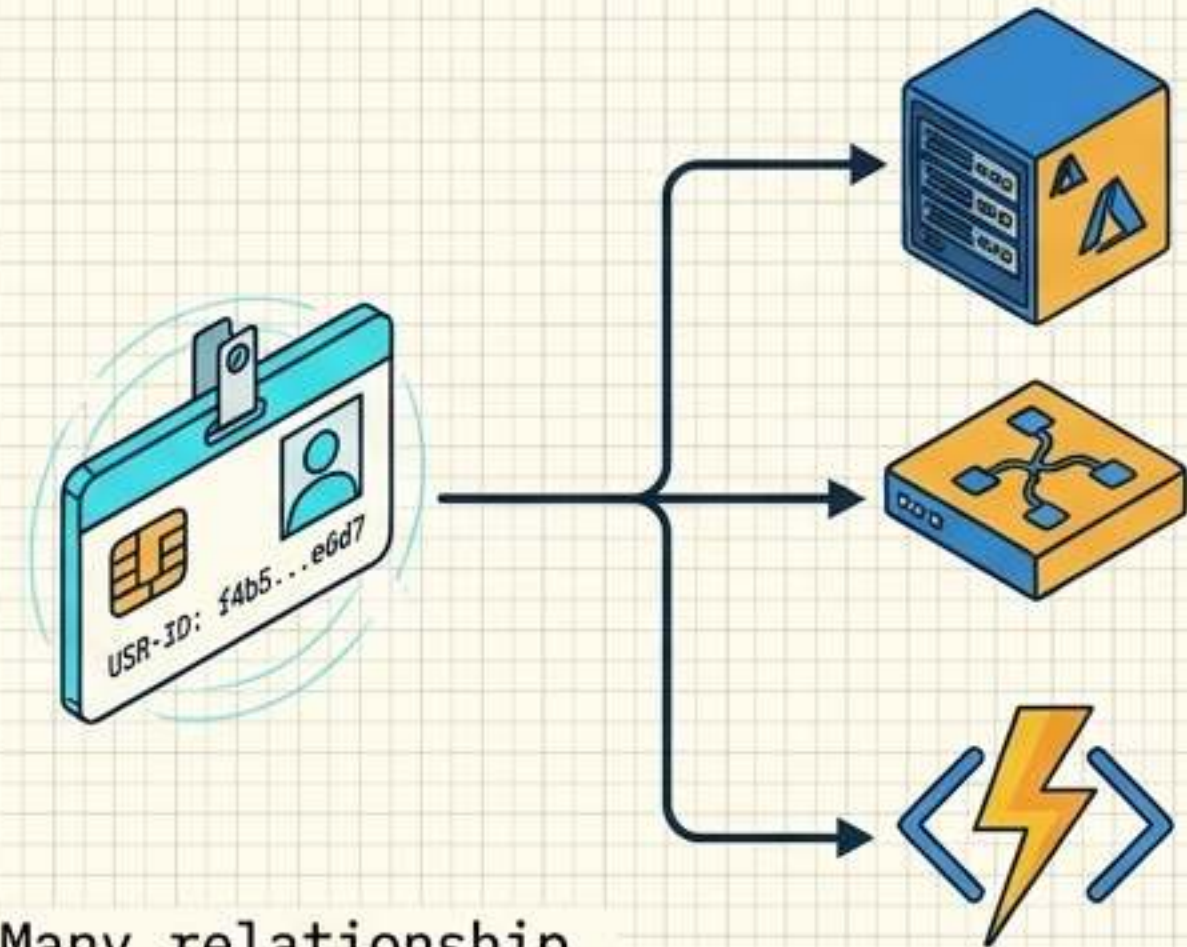
Managed Identities let Azure handle credentials automatically.

System-Assigned



- 1:1 relationship.
- Permanently tied to the resource lifecycle.
- Deleted automatically when the resource is deleted.

User-Assigned



- 1:Many relationship.
- Independent lifecycle.
- Shared across multiple resources (e.g., a fleet of identical VMs).

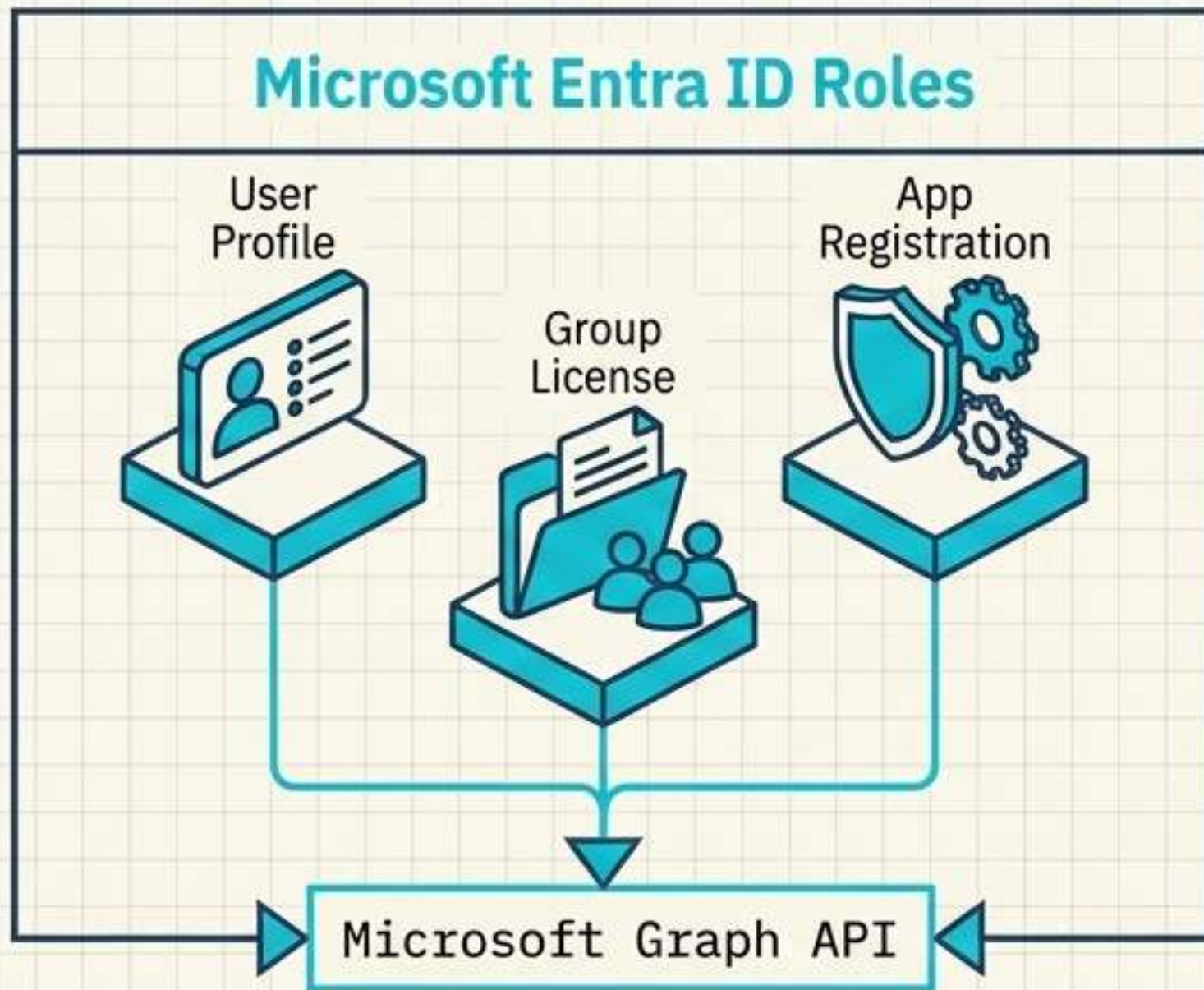
Diagnostic Matrix: Selecting Non-Human Identities

	Service Principal	System-Assigned MI	User-Assigned MI
Credential Management	Developer Manages	Azure Manages	Azure Manages
Cross-Tenant Support	Yes ✓	No ✗	No ✗
Lifecycle Tie	Independent	Tied to Resource	Independent
Setup Complexity	High (Secrets rotation)	Minimal (1 click)	Low (Pre-provisioned)
Best Use Case	3rd Party / External tools	Single isolated workload	Shared fleet of resources

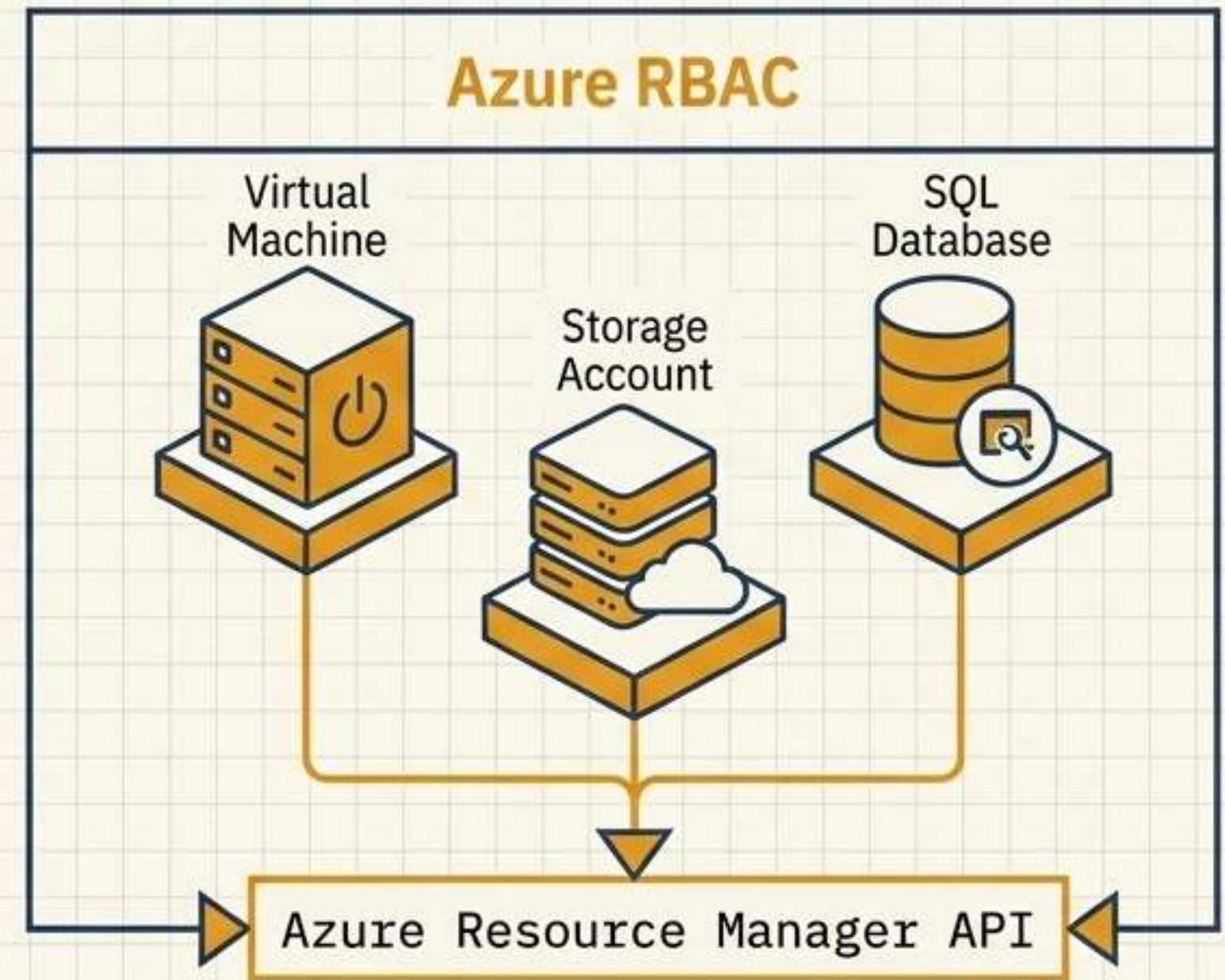
Insight: Always default to Managed Identities if the Azure service supports it. Fall back to Service Principals only for cross-tenant scenarios or external automated tools.

The Great Divide: Microsoft Entra Roles vs. Azure RBAC

Both systems share the same underlying architecture (Principal + Role + Scope), but they are NOT interchangeable.



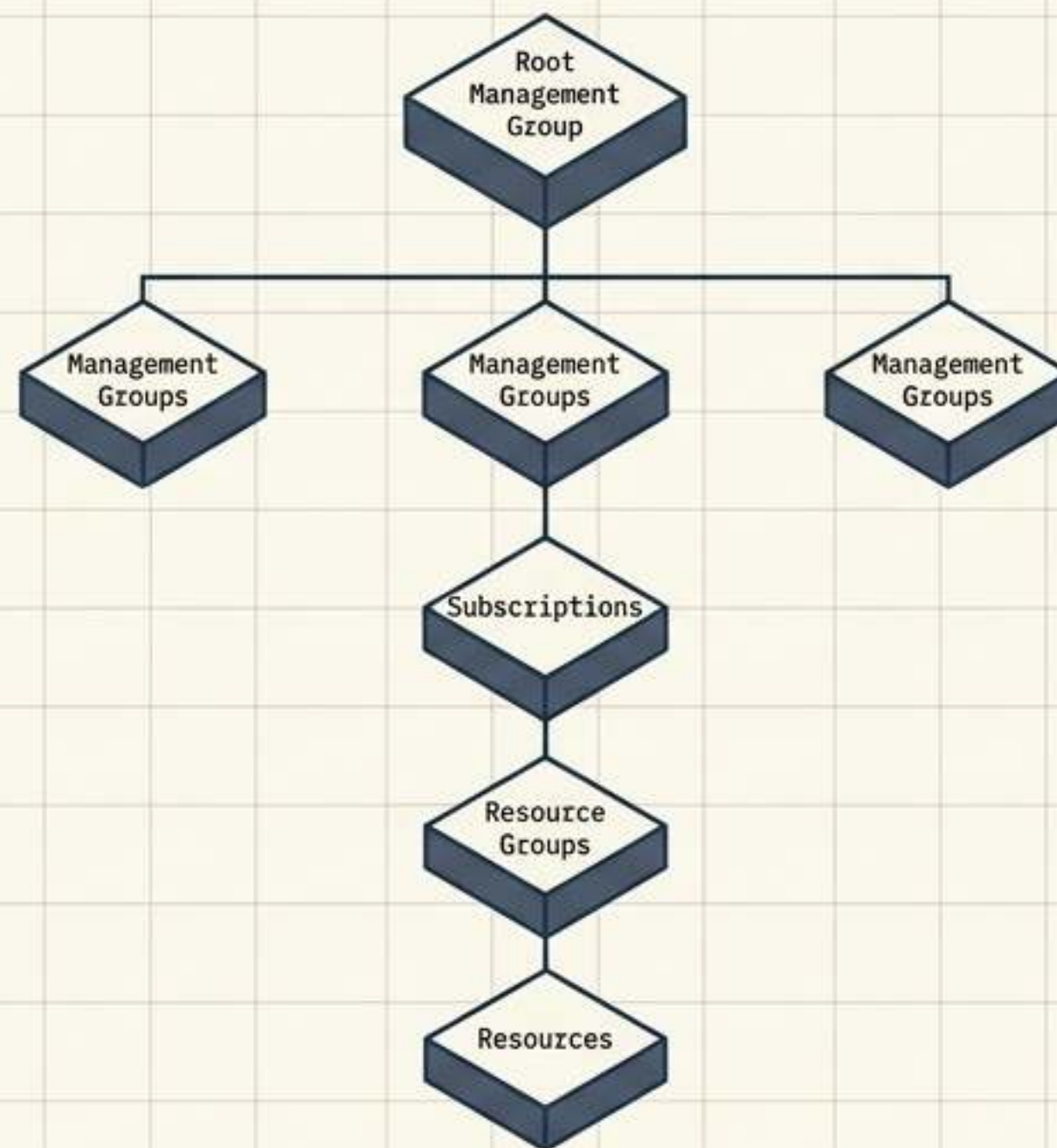
Controls the management of the directory itself (e.g., Global Admin, User Admin, App Admin).



Controls access to Azure infrastructure resources (e.g., Virtual Machine Contributor, Storage Blob Data Reader).

Azure Governance Architecture and Inheritance

Absolute Inheritance
Governance applied at any level cascades down to EVERYTHING nested beneath it.



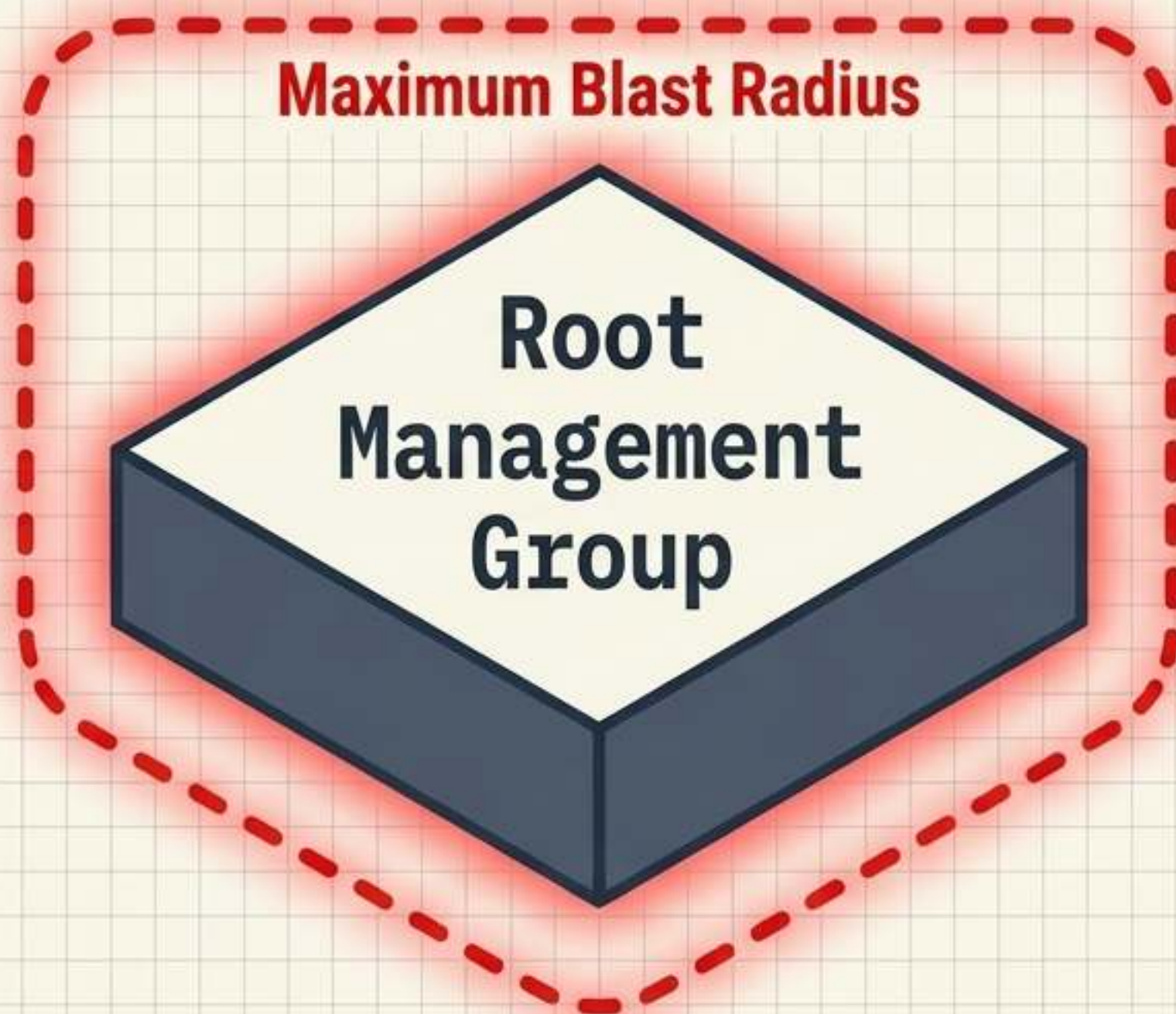
Structural Limits

- **Nesting:** Up to 6 levels deep (excluding root and subscriptions).
- **Scale:** Up to 10,000 management groups per directory.

Warning: Assignments at higher scopes cannot be overridden by lower scopes. A Deny assignment at the Management Group level beats an Allow assignment at the Resource level.

Deep Dive: The Root Management Group

The absolute top of the hierarchy. Every directory has exactly one. All subscriptions fold into it.



Key Characteristics

The Blast Radius

Any policy or role assignment here applies to EVERY SINGLE RESOURCE in the entire directory.

Access Mechanics

No user gets default access to manage it. A Global Administrator must explicitly elevate themselves to the User Access Administrator role to configure it.

Immutability

Unlike standard management groups, it cannot be moved or deleted.

The Anatomy of a Role Assignment

Access is granted by creating this three-part assignment.

[Security Principal] + [Role Definition] + [Scope] = [Access]

Who

User, Group,
Service Principal,
Managed Identity

What

A JSON collection of
allowed and denied
Actions / DataActions

Where

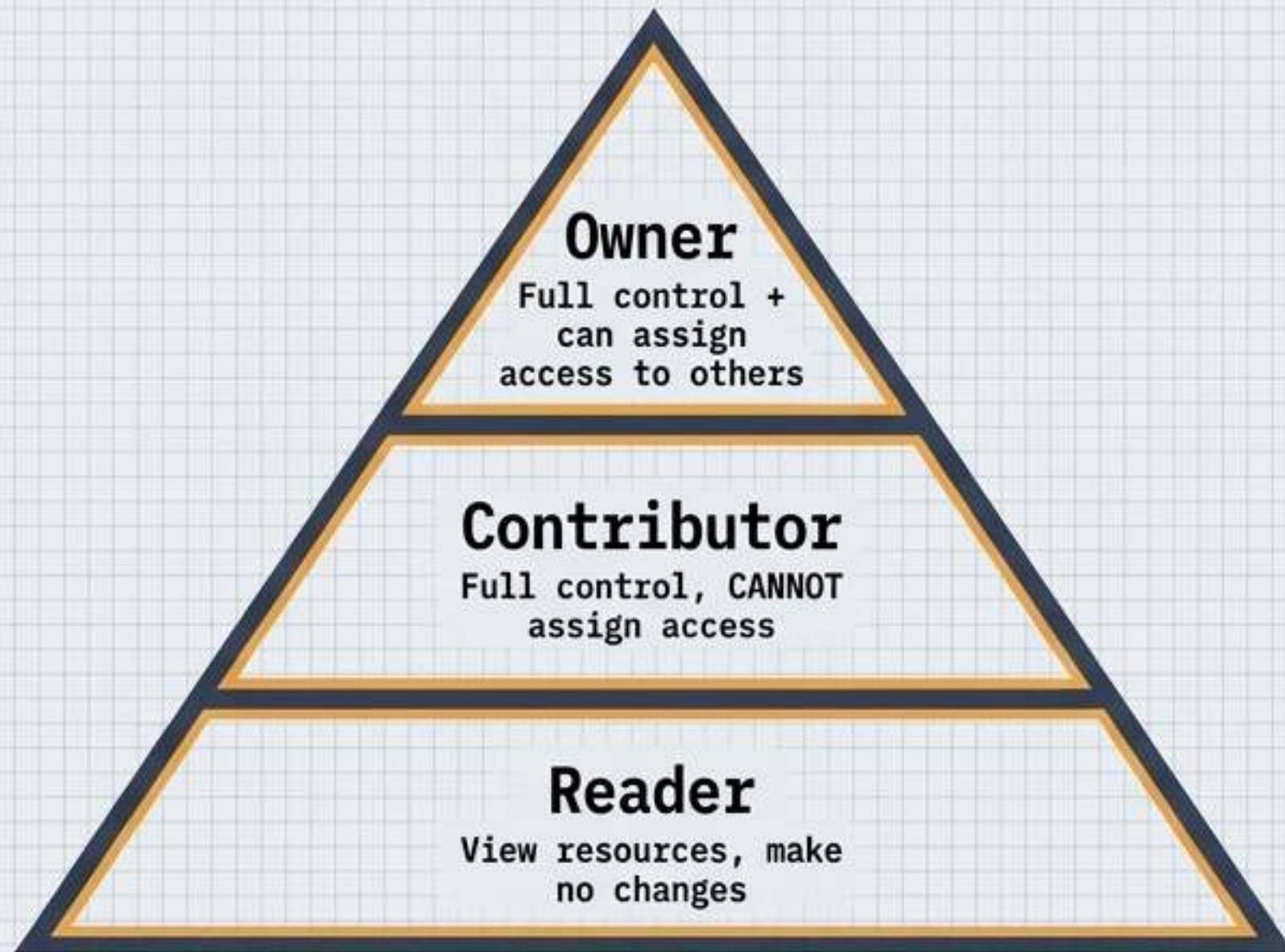
Management Group,
Subscription,
Resource Group, or
specific Resource



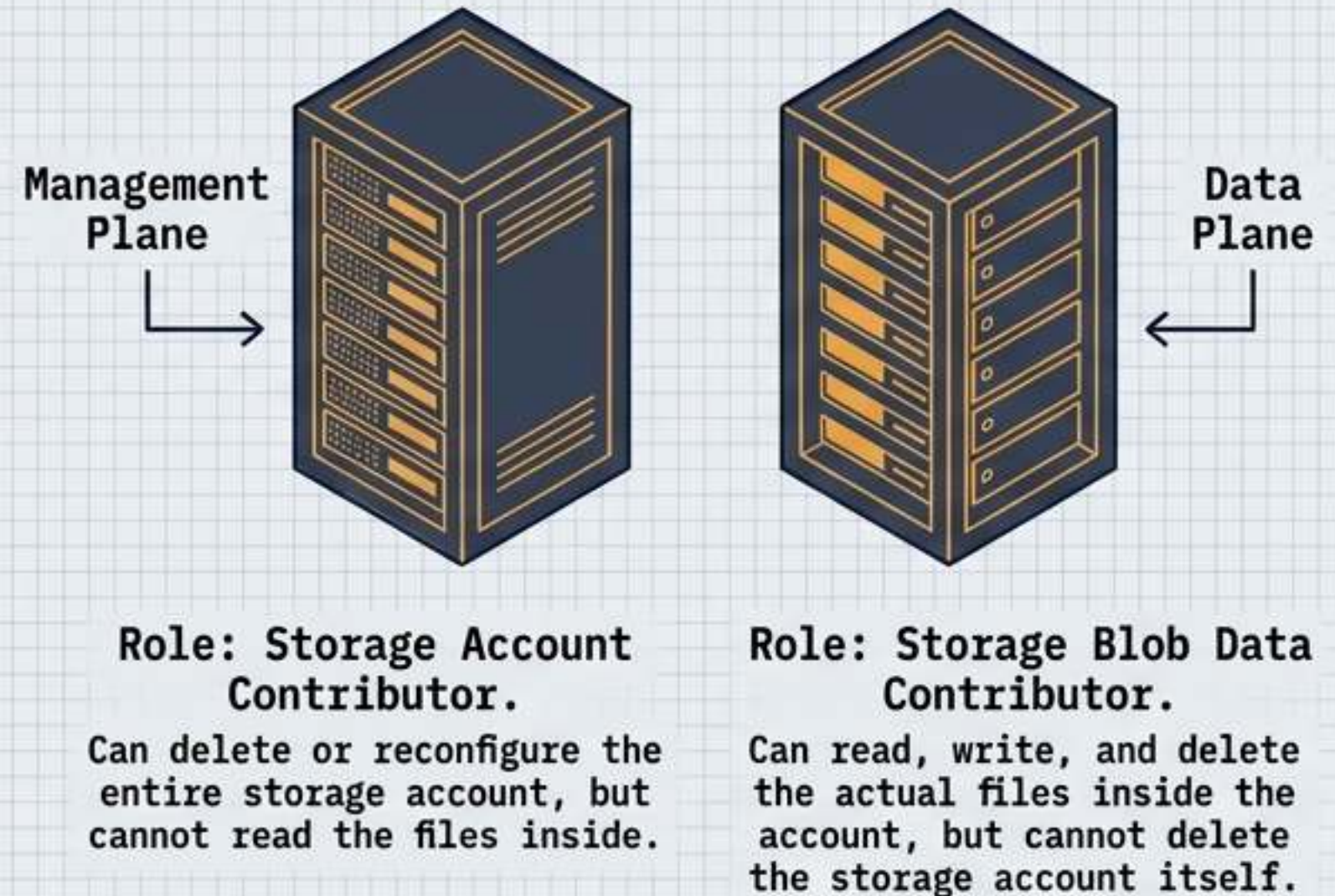
Architect's Rule of Thumb: Apply the principle of least privilege. Assign the narrowest possible role at the narrowest possible scope.

Deciphering Built-In Azure Roles

The Universal Three



Management vs. Data Plane



Never conflate the two.

Bridging the Gaps: Custom Roles

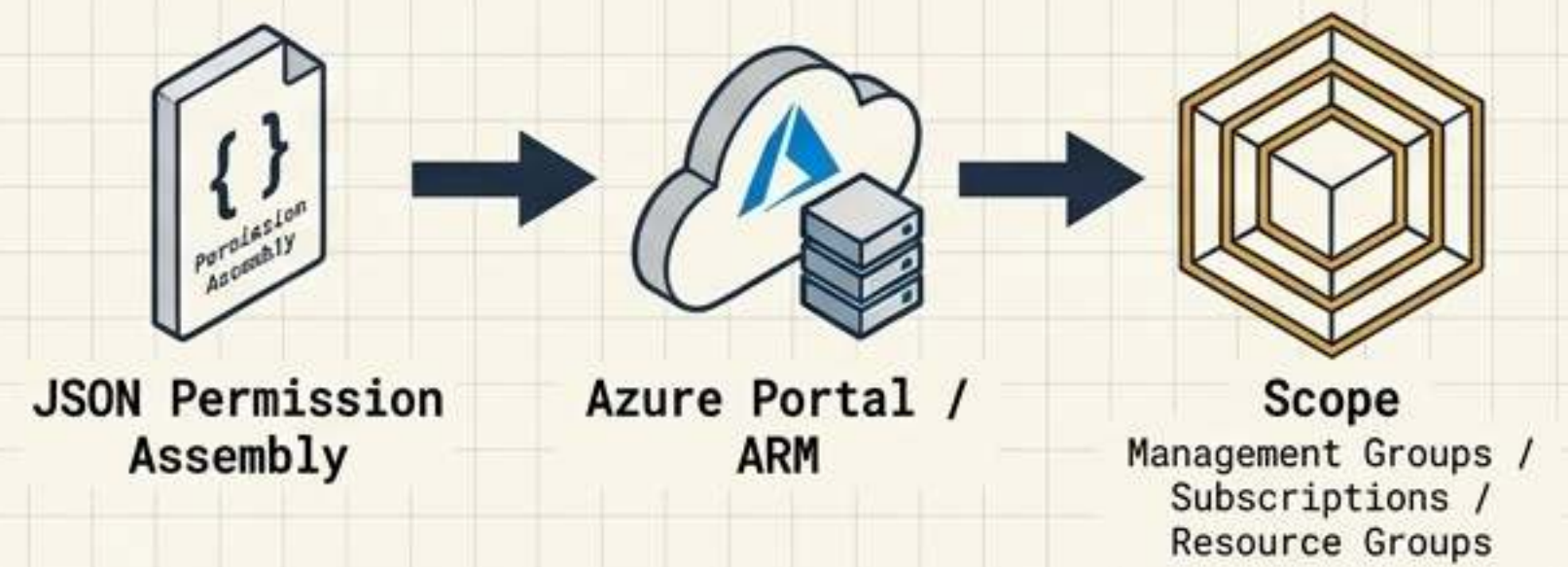
When Built-in roles grant too much access, strict Just-Enough-Access (JEA) requires Custom Roles.

Entra Custom Roles



- Created in the Entra Admin Center.
- Requires an Entra ID P1 license.
- Assignments scoped to: Tenant, Administrative Unit, or a specific App.

Azure RBAC Custom Roles



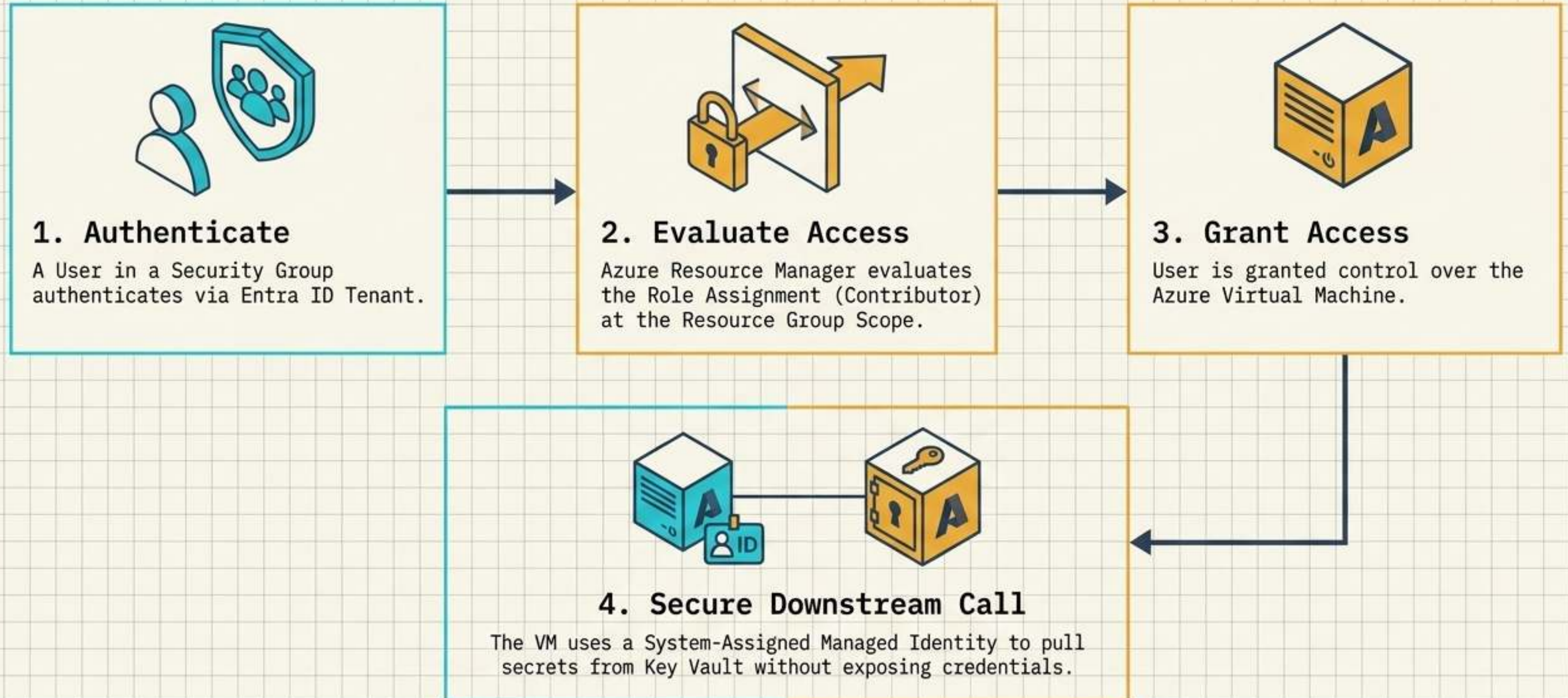
- Created via ARM / Azure Portal.
- Free to use.
- Assignments scoped to: Management Groups, Subscriptions, or Resource Groups.



Warning: The permission systems are isolated. You cannot put Entra Graph API permissions inside an Azure RBAC Custom Role.

Synthesis: The Unified Security Model

How Identity, Governance, and Infrastructure interact in a single, secure lifecycle request.



Blueprint Summary & Best Practices



Identity

Default to Managed Identities for automated workloads.
Avoid manual Service Principal secrets.



Access

Never assign roles directly to users; assign roles exclusively to Security Groups for scalable governance.



Hierarchy

Use Management Groups to align governance with business structure, rather than applying policies per-subscription.



RBAC

Strictly respect the Data Plane vs. Management Plane split, especially for Storage and Key Vault.



Safety

Protect the Root Management Group at all costs; restrict Global Admin elevation.

Glossary of Critical Distinctions

Term A	Term B	The Core Distinction
User	Guest	Internal Entra credential vs. Federated external credential.
App Object	Service Principal	Global blueprint definition vs. Local instantiated tenant instance.
System-Assigned MI	User-Assigned MI	1:1 resource-tied lifecycle vs. 1:Many independent shared lifecycle.
Entra Role	Azure RBAC	Microsoft Graph API (Directory Identity) vs. Azure Resource Manager (Cloud Infrastructure).
Management Plane	Data Plane	Control over the resource container vs. Control over the data inside the container.